

SecurityGroup101

Security Trust Center

Security Posture · Compliance · Data Protection · Incident Response

Last Updated: July 2026 | Contact: security@securitygroup101.com

Company Overview

SecurityGroup101 is a cloud-native fintech SaaS company founded in 2025, providing financial analytics, digital payment processing, and governance, risk, and compliance (GRC) tooling for mid-market financial institutions. We operate exclusively on Amazon Web Services in US-only regions and maintain a comprehensive security program aligned to NIST CSF 2.0, ISO 27001:2022, PCI DSS v4.0, and the GLBA Safeguards Rule.

Founded	2025
Headquarters	Chicago, IL
Cloud Provider	Amazon Web Services (AWS)
Data Regions	us-east-1 — Primary us-west-2 — Disaster Recovery
Service Type	SaaS — multi-tenant with strict logical data isolation
Customers	Mid-market banks, credit unions, and fintech companies
GRC Portfolio	github.com/Mkjones10/securitygroup101-enterprise-grc-program

Compliance & Certifications

Framework / Regulation	Status	Notes
GLBA Safeguards Rule	Compliant	Annual gap analysis documented. Encryption, access control, incident response, and vendor management requirements fully addressed.
PCI DSS v4.0	Compliant	Full CCW crosswalk completed. SAQ-D maintained. Annual internal assessment; quarterly vulnerability scans per Req 11.
FFIEC Cybersecurity	Aligned	Cybersecurity Assessment Tool (CAT) baseline posture documented. Controls mapped across all five FFIEC cybersecurity domains.
SOX IT General Controls	Aligned	Change management, access control, segregation of duties, and audit logging controls documented and tested.
NIST CSF 2.0	Implemented	Full implementation across Govern, Identify, Protect, Detect, Respond, and Recover function areas.
ISO 27001:2022	In Progress	Statement of Applicability documented. Annex A control mapping complete. Third-party certification targeted Q4 2026.

Framework / Regulation	Status	Notes
SOC 2 Type II	In Progress	Readiness assessment completed. Trust Services Criteria gap analysis underway. Type II audit targeted Q2 2027.
NIST SP 800-53 Rev 5	Reference	Control family mapping maintained in unified control catalog. Used as baseline for control selection and testing.

Data Security — Encryption Standards

Encryption at Rest	AES-256 for all customer data. AWS S3 server-side encryption with Customer Managed Keys (SSE-KMS). Database volumes encrypted via AWS KMS. Sensitive financial data fields (PAN, account numbers, SSNs) additionally encrypted at the application layer (defense in depth). FIPS 140-2 validated modules.
Encryption in Transit	TLS 1.2 or higher enforced on all endpoints. TLS 1.0 and 1.1 explicitly disabled. HTTP automatically redirected to HTTPS. Certificate management via AWS Certificate Manager with automatic renewal.
Key Management	AWS KMS for full key lifecycle (creation, rotation, retirement). Automatic annual rotation for all Customer Managed Keys. Key access restricted to authorized IAM roles; all usage logged in AWS CloudTrail. BYOK (Bring Your Own Key) available for enterprise customers.
Data Classification	Four tiers: Restricted (PAN, SSNs, PHI — highest controls); Confidential (customer PII, contracts); Internal (business operations); Public. Classification tier determines encryption, access control, and retention requirements.

Access Control & Identity Management

Access Type	MFA Requirement	Method
Production systems & admin consoles	Required — no exceptions	FIDO2 hardware token (privileged); Authenticator app (standard)
AWS Management Console	Required — IAM policy enforced	AWS IAM MFA with hardware or virtual token
Customer administrative portal	Required	Authenticator app or hardware security key
VPN / remote access	Required	Certificate-based authentication + MFA
Standard customer access	Required	TOTP or push notification

Least-privilege RBAC enforced — 7 defined roles across 54 functional modules with field-level security controls. Privileged accounts separated from standard accounts with JIT access to cloud consoles. Access reviews: privileged accounts quarterly; standard accounts semi-annually.

Incident Response

Severity	Definition	Response SLA	Customer Notification
Critical	Confirmed data breach, ransomware, or full system compromise	Immediate	Within 72 hours of breach determination
High	Unauthorized access, significant DDoS, major service degradation	4 hours	Within 24 hours as appropriate
Medium	Policy violation, malware detected, partial service degradation	24 hours	As appropriate

Severity	Definition	Response SLA	Customer Notification
Low	Failed access attempts, anomalous activity, minor events	5 bus. days	Not required

Business Continuity & Recovery Objectives

Asset Tier	Examples	RTO	RPO
Tier 1 — Critical	Financial processing, payment APIs, authentication	4 hours	1 hour
Tier 2 — Core	Analytics platform, reporting, customer portal	8 hours	4 hours
Tier 3 — Non-critical	Admin tools, internal dashboards, dev environments	24 hours	24 hours

BCP/DRP tested annually (tabletop exercises and failover drills). AWS multi-region active-passive architecture. Backup retention: 30 days hot, 12 months archive.

Vendor & Subprocessor Disclosure

Customers are notified of subprocessor changes with 30 days advance written notice. All subprocessors undergo security assessment prior to engagement and must meet contractual security requirements equivalent to SecurityGroup101's own standards.

Subprocessor	Service	Data Processed	Region
Amazon Web Services (AWS)	Cloud infrastructure	All customer data (encrypted at rest and in transit)	US only
Stripe	Payment processing	Payment card data only (PCI DSS scoped)	US
Datadog	Infrastructure monitoring	Log data and performance metrics (no customer PII)	US
Okta	Identity provider (internal)	Employee authentication data only	US

Vulnerability Management & Penetration Testing

Activity	Frequency	Scope
Automated vulnerability scanning	Weekly	All production infrastructure
Web application security assessment	Quarterly	All customer-facing applications (OWASP Top 10)
External penetration testing	Annually	Network perimeter, web apps, APIs, cloud infrastructure
Internal penetration testing	Semi-annually	Internal infrastructure and applications
Container image scanning	Every build	All container images in CI/CD pipeline

Remediation SLAs: Critical — 24 hours | High — 7 days | Medium — 30 days | Low — 90 days. Executive summary of penetration test results available to enterprise customers under NDA upon written request.

Contact Security

Security questionnaires & vendor assessments	security@securitygroup101.com
Vulnerability disclosure / responsible disclosure	security@securitygroup101.com (response within 48 hours)
Privacy inquiries & data subject access requests	privacy@securitygroup101.com (30-day SLA)
Security incidents (24/7 monitoring)	security@securitygroup101.com
Contract security requirements	legal@securitygroup101.com
GRC Portfolio Repository	github.com/Mkjones10/securitygroup101-enterprise-grc-program

This Security Trust Center is a GRC portfolio artifact created by Maxine Jones, GRC Analyst (mkj00015@mix.wvu.edu). SecurityGroup101 is a fictional fintech SaaS company founded 2025. All documented controls are grounded in the Enterprise GRC Program: github.com/Mkjones10/securitygroup101-enterprise-grc-program. Frameworks: NIST CSF 2.0, ISO 27001:2022, NIST SP 800-53 Rev 5, PCI DSS v4.0, GLBA Safeguards Rule, FFIEC Cybersecurity, COBIT 2019.